

Организация
ПОЛИТИКА
ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

Регламент обеспечения информационной
безопасности

СОГЛАСОВАНО:
Руководитель службы ИБ

«_____» _____ 20__ г.

г. г. Омск, 2026

Содержание

0.1	Основания и цели регламента	2
0.1.1	Основания	2
0.1.2	Цели	2
0.2	Процедуры и процессы	2
0.2.1	Определение роли руководства	2
0.2.2	Определение роли отдела информационной безопасности	2
0.2.3	Определение роли сотрудников	3
0.3	Заключение	3
0.4	2.1 Проведение аудита информационной безопасности	4
0.4.1	Объекты аудита	4
0.4.2	Процедура проведения аудита	4
0.4.3	Ссылки на нормативные документы	5
0.5	2.2 Обновление и актуализация документации СУИБ	5
0.5.1	Объекты обновления	5
0.5.2	Процедура обновления и актуализации документации . .	5
0.5.3	Ссылки на нормативные документы	6
0.6	2.3 Обработка и хранение персональных данных	6
0.6.1	Объекты обработки	6
0.6.2	Процедура обработки и хранения персональных данных	6
0.6.3	Ссылки на нормативные документы	7
0.6.4	3. Роли и ответственность	7
0.6.5	4. Контроль исполнения	9

0.1 Основания и цели регламента

0.1.1. Основания

Разработка и внедрение настоящего регламента по информационной безопасности (далее — Регламент) осуществляется в соответствии с требованиями Федерального закона от 27.07.2006 г. № 152-ФЗ “О персональных данных” [152-ФЗ, ст. 19], Государственного стандарта Российской Федерации по информационной безопасности (ГОСТ Р) 57580-2017 “Информационная безопасность организаций. Общие требования” [ГОСТ Р 57580-2017, п. 6.3], а также Правилами обеспечения информационной безопасности в Российской Федерации, утвержденными постановлением Федеральной службы по техническому и экспортному контролю РФ от 29.12.2015 г. № 239 [ФСТЭК России №239, раздел 5].

0.1.2. Цели

Целью настоящего Регламента является обеспечение защиты информации, обрабатываемой в ООО “МИАЦ”, от несанкционированного доступа, изменения, уничтожения и разглашения, а также предотвращение возможных угроз информационной безопасности. Это достигается путем установления четких процедур и процессов, определения ролей и ответственности сотрудников организации.

0.2 Процедуры и процессы

0.2.1. Определение роли руководства

Руководство ООО “МИАЦ” возлагает на себя обязанность обеспечивать создание и поддержку эффективной системы управления информационной безопасностью (СУИБ). Для этого осуществляется разработка стратегии информационной безопасности, утверждение политики в области информационной безопасности и обеспечение финансирования мероприятий по ее реализации [ФСТЭК России №239, раздел 5].

0.2.2. Определение роли отдела информационной безопасности

Отдел информационной безопасности возлагает на себя обязанность разработки и внедрения мер по обеспечению информационной безопасности. Для

этого осуществляются следующие процедуры:

- **Анализ угроз:** Производится регулярный анализ угроз, с которыми может столкнуться организация [ГОСТ Р 57580-2017, п. 6.3].
- **Разработка мер защиты:** На основе анализа угроз разрабатываются и внедряются меры защиты информации.
- **Контроль за соблюдением требований:** Контроль за соблюдением установленных требований осуществляется через регулярные аудиты и проверки [ФСТЭК России №239, раздел 5].

0.2.3. Определение роли сотрудников

Сотрудники ООО «МИАЦ» возлагают на себя обязанность соблюдения правил информационной безопасности при выполнении своих профессиональных обязанностей. Для этого осуществляются следующие процедуры:

- **Обучение и информирование:** Производится обучение сотрудников по вопросам информационной безопасности, а также регулярное информирование о новых угрозах и мерах защиты [152-ФЗ, ст. 19].
- **Соблюдение правил доступа к информации:** Сотрудники обязаны соблюдать установленные правила доступа к информации в зависимости от уровня ее чувствительности.
- **Регистрация и учет:** Все действия сотрудников по работе с информацией должны быть зарегистрированы и учтены для обеспечения возможности контроля и анализа [ГОСТ Р 57580-2017, п. 6.3].

0.3 Заключение

Настоящий Регламент по информационной безопасности является основным документом для организации деятельности ООО «МИАЦ» в области обеспечения информационной безопасности и направлен на обеспечение защиты информации от возможных угроз.

[152-ФЗ, ст. 19] Федеральный закон от 27.07.2006 г. № 152-ФЗ “О персональных данных”

[ГОСТ Р 57580-2017, п. 6.3] Государственный стандарт Российской Федерации по информационной безопасности (ГОСТ Р) 57580-2017 “Информационная безопасность организаций. Общие требования”

[ФСТЭК России №239, раздел 5] Правила обеспечения информационной безопасности в Российской Федерации, утвержденные постановлением Федеральной службы по техническому и экспортному контролю РФ от 29.12.2015 г. № 239

0.4 2.1 Проведение аудита информационной безопасности

0.4.1. Объекты аудита

Аудит информационной безопасности осуществляется для проверки соответствия системы управления информационной безопасностью (СУИБ) требованиям нормативных документов и стандартов.

Исполнитель: Отдел информационной безопасности

Ответственность возлагается на: Отдел информационной безопасности, который проводит аудит в соответствии с установленными процедурами.

Контроль осуществляет: Департамент внутреннего контроля и надзора

0.4.2. Процедура проведения аудита

1. Подготовка к аудиту:

- Определение целей и задач аудита.
- Разработка плана аудита, согласованный с контролирующей стороной.

2. Проведение аудита:

- Проверка документации СУИБ на соответствие требованиям [ГОСТ Р 57580-2017, п. 6.3].
- Анализ текущих процессов и процедур в области информационной безопасности.
- Оценка эффективности реализации мер по обеспечению информационной безопасности.

3. Отчетность:

- Подготовка отчета об аудите с выявлением несоответствий и предложений по их устранению.

- Представление отчета руководству организации для принятия решений о дальнейших действиях.

0.4.3. Ссылки на нормативные документы

- [ГОСТ Р 57580-2017, п. 6.3]
- [ФСТЭК России №239, раздел 5]

0.5 2.2 Обновление и актуализация документации СУИБ

0.5.1. Объекты обновления

Обновление и актуализация документации СУИБ осуществляются для обеспечения соответствия системы требованиям действующих нормативных документов.

Исполнитель: Отдел информационной безопасности

Ответственность возлагается на: Отдел информационной безопасности, который отвечает за регулярное обновление и актуализацию документации СУИБ.

Контроль осуществляет: Департамент внутреннего контроля и надзора

0.5.2. Процедура обновления и актуализации документации

1. Определение требований:

- Анализ изменений в действующих нормативных документах.
- Оценка необходимости обновления существующей документации.

2. Разработка изменений:

- Подготовка проектов изменений к документам СУИБ.
- Обсуждение и согласование изменений с заинтересованными сторонами.

3. Актуализация документации:

- Внесение изменений в существующие документы.
- Создание новых документов, если это необходимо.

4. Распространение информации:

- Уведомление всех сотрудников о внесенных изменениях и актуализированных документах.

— Обучение персонала новым требованиям и процедурам.

0.5.3. Ссылки на нормативные документы

- [ГОСТ Р 57580-2017, п. 6.3]
- [ФСТЭК России №239, раздел 5]

0.6 2.3 Обработка и хранение персональных данных

0.6.1. Объекты обработки

Обработка и хранение персональных данных осуществляются в соответствии с действующими законодательными актами.

Исполнитель: Отдел информационной безопасности

Ответственность возлагается на: Отдел информационной безопасности, который отвечает за организацию обработки и хранения персональных данных в соответствии с требованиями закона.

Контроль осуществляет: Департамент внутреннего контроля и надзора

0.6.2. Процедура обработки и хранения персональных данных

1. Определение целей:

- Определение целей обработки персональных данных.
- Установление сроков хранения информации.

2. Обеспечение безопасности:

- Применение мер по защите персональных данных от несанкционированного доступа, уничтожения или изменения.
- Использование криптографических методов защиты информации.

3. Регистрация и учет:

- Регистрация всех операций с персональными данными в журнале событий.
- Подготовка отчетности о хранении и обработке данных.

4. Уничтожение информации:

- Организация уничтожения персональных данных по истечении установленного срока хранения.

- Подтверждение выполнения процедуры уничтожения документально.

0.6.3. Ссылки на нормативные документы

- [152-ФЗ, ст. 19]
 - [ГОСТ Р 57580-2017, п. 6.3]
-

Эти процедуры обеспечивают систематизированное и организованное выполнение задач по обеспечению информационной безопасности в организации ООО «МИАЦ».

0.6.4. 3. Роли и ответственность

3.1 Основные роли и их распределение Роль №1: Исполнитель по обеспечению информационной безопасности

- **Ответственность:** Производится мониторинг состояния информационных систем, выявление уязвимостей, проведение проверок соответствия нормативным требованиям.
- **Контроль осуществляет:** Департамент информационной безопасности.

Роль №2: Исполнитель по управлению рисками

- **Ответственность:** Осуществляется анализ и оценка рисков, разработка мер по их минимизации.
- **Контроль осуществляет:** Комитет по управлению рисками.

Роль №3: Исполнитель по обеспечению конфиденциальности данных

- **Ответственность:** Производится контроль за соблюдением политик конфиденциальности, обеспечение защиты персональных данных.
- **Контроль осуществляет:** Департамент информационной безопасности совместно с отделом кадров.

Роль №4: Исполнитель по обеспечению доступа к информации

- **Ответственность:** Осуществляется управление правами доступа, обеспечение соответствия политикам доступа.
- **Контроль осуществляет:** Департамент информационной безопасности.

Роль №5: Исполнитель по обеспечению надежности и Availability систем

- **Ответственность:** Производится мониторинг работы систем, обеспечение их бесперебойной работы.
- **Контроль осуществляет:** Департамент информационной безопасности.

Роль №6: Исполнитель по обеспечению защиты от несанкционированного доступа

- **Ответственность:** Осуществляется мониторинг сети, выявление и предотвращение попыток несанкционированного доступа.
- **Контроль осуществляет:** Департамент информационной безопасности.

3.2 Ссылки на нормативные документы

1. “[ГОСТ Р 57580-2017, п. 6.3]”: Устанавливает требования к обеспечению информационной безопасности в организациях.
2. “[ФСТЭК России №239, раздел 5]”: Определяет обязанности и права субъектов информационной безопасности.
3. “[152-ФЗ, ст. 19]”: Предусматривает меры по защите информации и обеспечение ее конфиденциальности.

3.3 Конкретные процедуры Процедура №1: Мониторинг состояния информационных систем

- **Исполнитель:** Исполнитель по обеспечению информационной безопасности.
- **Описание:** Производится регулярный мониторинг состояния информационных систем с целью выявления уязвимостей и нарушений.

Процедура №2: Анализ и оценка рисков

- **Исполнитель:** Исполнитель по управлению рисками.
- **Описание:** Осуществляется регулярный анализ и оценка рисков, разработка мер по их минимизации.

Процедура №3: Контроль за соблюдением политик конфиденциальности

- **Исполнитель:** Исполнитель по обеспечению конфиденциальности данных.

- **Описание:** Производится контроль за соблюдением политик конфиденциальности, обеспечение защиты персональных данных.

Процедура №4: Управление правами доступа

- **Исполнитель:** Исполнитель по обеспечению доступа к информации.
- **Описание:** Осуществляется управление правами доступа, обеспечение соответствия политикам доступа.

Процедура №5: Мониторинг работы систем

- **Исполнитель:** Исполнитель по обеспечению надежности и Availability систем.
- **Описание:** Производится мониторинг работы информационных систем с целью обеспечения их бесперебойной работы.

Процедура №6: Мониторинг сети

- **Исполнитель:** Исполнитель по обеспечению защиты от несанкционированного доступа.
- **Описание:** Осуществляется мониторинг сети с целью выявления и предотвращения попыток несанкционированного доступа.

Таким образом, распределение ролей и ответственности в ООО «МИАЦ» обеспечивает комплексное управление информационной безопасностью организации.

0.6.5. 4. Контроль исполнения

4.1 Общие положения Контроль за исполнением регламентов по информационной безопасности осуществляется на всех уровнях организации ООО «МИАЦ». Основные функции контроля возлагаются на отдел информационной безопасности, который также обеспечивает мониторинг и оценку эффективности реализации мер по обеспечению информационной безопасности.

4.2 Методы мониторинга Для обеспечения надлежащего контроля за исполнением регламентов по информационной безопасности используются следующие методы:

1. Аудит внутренних процессов:

- Производится периодически, с целью выявления несоответствий и недостатков в работе системы управления информационной безопасностью.
- Аудит осуществляет отдел информационной безопасности.

2. Мониторинг систем мониторинга и контроля:

- Ведется непрерывно для выявления нарушений и обеспечения соответствия установленным требованиям.
- Мониторинг производится специализированными программными средствами, управление которыми возложено на отдел информационной безопасности.

3. Обзор текущих отчетов:

- Проводится регулярно для анализа выполнения задач и выявления возможных рисков.
- Обзор текущих отчетов осуществляется руководством отдела информационной безопасности.

4.3 Распределение ролей и ответственности

- **Ответственность за проведение аудитов внутренних процессов** возлагается на отдел информационной безопасности.
- **Контроль за мониторингом систем мониторинга и контроля** осуществляется также отделом информационной безопасности.
- **Обзор текущих отчетов** проводится руководством отдела информационной безопасности.

4.4 Ссылки на нормативные документы

1. [ГОСТ Р 57580-2017, п. 6.3] — требует регулярного проведения аудитов внутренних процессов для выявления несоответствий и недостатков.
2. [ФСТЭК России №239, раздел 5] — предписывает использование специализированных программных средств для мониторинга систем безопасности.
3. [152-ФЗ, ст. 19] — требует регулярного обзора текущих отчетов для анализа выполнения задач и выявления рисков.

4.5 Конкретные процедуры

1. Аудит внутренних процессов:

- Планирование аудита.
- Выполнение аудита с использованием стандартных методик.
- Формирование отчета о результатах аудита.

2. Мониторинг систем мониторинга и контроля:

- Настройка и поддержка программного обеспечения для мониторинга.
- Анализ данных, полученных от систем мониторинга.
- Формирование отчетов о состоянии системы мониторинга.

3. Обзор текущих отчетов:

- Сбор и анализ текущих отчетов по информационной безопасности.
- Оценка соответствия выполненным задач установленным требованиям.
- Подготовка рекомендаций для устранения выявленных недостатков.

Таким образом, контроль за исполнением регламентов по информационной безопасности в ООО «МИАЦ» осуществляется с учетом требований нормативных документов и направлен на обеспечение стабильности и надежности системы управления информационной безопасностью.

5. Ответственность за нарушения

5.1 Определение нарушений информационной безопасности

На основании нормативных документов, ответственность за наруш

5.2 Санкции и меры по отношению к нарушителям

1. **Нарушение требований к защите персональных данных**

В случае выявления нарушений, связанных с неправильным хране

Ссылка: [Федеральный закон №152-ФЗ "О персональных данных

2. **Нарушение требований к защите информации**

При нарушении требований к защите информации, ответственнос

Ссылка: [Федеральный закон №152-ФЗ "О персональных данных"]

3. **Нарушение требований к защите информации в сети Интернет*

В случае нарушения требований к защите информации в сети Инт

Ссылка: [Федеральный закон №152-ФЗ "О персональных данных"]

4. **Нарушение требований к защите информации при использовании*

При нарушении требований к защите информации при использован

Ссылка: [ГОСТ Р 57580-2017, п. 6.3]

5.3 Протоколы нарушений

Для каждого выявленного нарушения составляется протокол, кото

5.4 Уведомление о нарушении

В случае выявления нарушения информационной безопасности, соо

5.5 Меры по предотвращению повторных нарушений

Для предотвращения повторных нарушений принимаются меры в соот

5.6 Ответственность за неисполнение обязанностей

Неисполнение или ненадлежащее исполнение обязанностей по обес

5.7 Обратная связь

Для получения обратной связи и улучшения системы контроля за и